Pontifícia Universidade Católica de Minas Gerais

***Campus* Poços de Caldas**

Curso de Ciência da Computação

CyberOne | cyberonelab.org

Laboratório de Computação Forense, Perícia Computacional e Inteligência Cibernética

CASO HIPOTÉTICO E ESTRATÉGIAS DE INVESTIGAÇÃO CIBERNÉTICA

OPERAÇÃO "*ENCOMENDA RETIDA*"

Aluno

Vinicius Fernandes Betti

Orientador

Prof. Dr. João Benedito dos Santos Junior

Professor Adjunto IV | Perito Forense Computacional

Outubro de 2026

Caso Hipotético Operação Encomenda Retida

1 Finalidade e Vínculo com o Trabalho de Diplomação

Este documento formaliza o caso prático do Trabalho de Diplomação sobre Investigação Cibernética OSINT multifonte. A missão consiste em aplicar, comparar e documentar técnicas, procedimentos e ferramentas para examinar uma campanha hipotética de phishing que personifica os Correios. O caso converte os testes realizados no Estágio Obrigatório em um fluxo verificável de recepção, preservação, análise, correlação, validação e apresentação de evidências.

2 Enunciado do Caso hipotético

Uma unidade policial recebe notícia de que cidadãos estão recebendo mensagens sobre uma suposta encomenda retida. A mensagem exige pagamento de taxa e direciona o destinatário para página que reproduz sinais visuais dos Correios. Um comunicante entrega um arquivo EML, uma captura da página, uma URL neutralizada, uma imagem empregada na mensagem e o horário aproximado do recebimento. A autoridade solicita a reconstrução técnica da infraestrutura e a avaliação dos indicadores, sem atribuição conclusiva de autoria.

A associação entre o e-mail sanitizado, os registros históricos e os demais objetos é parte da narrativa acadêmica. O aluno deverá declarar quando dois artefatos não possuírem vínculo comprovado e jamais apresentar a construção hipotética como campanha real única.

3 Objetos Reais e *Corpus* Investigativo

Código	Objeto Público Real	Finalidade e Cautela
V-01	Site oficial dos Correios: https://www.correios.com.br/	Referência legítima para domínio, certificado, identidade visual e infraestrutura
V-02	URLScan: https://urlscan.io/result/7d676f3d-82d0-4ae2-97ea-0e90875754d6/	Registro histórico do domínio pedidos-do-brasil.site; consultar o registro, não a página original
V-03	Registros URLScan de produtos-brasil.site, produtos-do-br.site, taxabrcorreios.com e enviopacotebr.online	Objetos comparativos históricos; neutralizar os domínios e registrar a data de cada captura
V-04	Corpus cw-l/email-corpus: https://github.com/cw-l/email-corpus	Selecionar um EML real, redigido e neutralizado; não presumir vínculo com os domínios

Código	Objeto Público Real	Finalidade e Cautela
V-05	PhishTank: https://phishtank.org/	Validar classificação histórica e metadados; não visitar URLs ativas
V-06	Certificate Transparency: https://crt.sh/	Relacionar nomes e períodos de validade sem varredura ativa
V-07	Wayback Machine e Archive.today	Pesquisar versões históricas e registrar lacunas de conteúdo dinâmico

4 Delimitação Ética, Jurídica e Segurança Operacional (OpSec)

1. Utilizar somente fontes abertas, registros históricos, dados sintéticos, ativos próprios ou expressamente autorizados;
2. Não abrir a URL maliciosa original, baixar conteúdo, executar código, preencher formulários ou transmitir informações;
3. Não realizar intrusão, exploração, enumeração agressiva, engenharia social, acesso a contas ou interação com vítimas e investigados;
4. Não submeter dados pessoais ou evidências sensíveis a serviços externos; trabalhar com cópias sanitizadas quando necessário;
5. Respeitar os termos de uso, limites de consulta, Marco Civil da Internet, Lei Geral de Proteção de Dados e cadeia de custódia;
6. Interromper a atividade e comunicar ao orientador caso surja conteúdo ilícito, dado pessoal não previsto ou infraestrutura ativa não autorizada.

5 Questões Investigativas

1. Quais propriedades do e-mail indicam origem, percurso, autenticação, falsificação ou anomalia?
2. Quais entidades podem ser extraídas e normalizadas: URL, domínio, subdomínio, IP, ASN, certificado, endereço de e-mail, hash e imagem?
3. Quais informações atuais e históricas convergem entre DNS, RDAP, certificados, reputação e preservação web?
4. Quais elementos visuais caracterizam personificação da marca e quais dependem de interpretação?
5. Quais requisições formais poderiam ser fundamentadas pelos achados sem extrapolar o que as fontes demonstram?

6 Estratégia de Investigação

Etapa	Ação Principal	Resultado
1 Recepção	Identificar objetos, origem, formato, responsável e circunstâncias de entrega	Termo de recebimento e inventário
2 Preservação	Copiar em modo controlado, calcular SHA-256, manter original e cópia de trabalho	Manifesto de hashes e cadeia de custódia
3 Triagem	Extrair cabeçalhos, URLs, domínios, IPs, anexos e metadados sem execução	Lista neutralizada de indicadores
4 Enriquecimento	Consultar RDAP, DNS, ASN, certificados, reputação e histórico	Fichas por fonte com horários UTC
5 Conteúdo	Comparar página histórica, logotipo, textos, formulários e recursos com o site legítimo	Matriz de personificação e divergências
6 Correlação	Unificar entidades, remover duplicidades e construir grafo e linha do tempo	Mapa de relações e sequência temporal
7 Validação	Confirmar resultados em fontes independentes e classificar confiança	Achados confirmados, divergentes ou inconclusivos
8 Relatório	Separar fatos, dados externos, correlações, inferências e hipóteses	Relatório técnico-pericial reproduzível

7 Procedimentos Técnicos Essenciais

7.1 Preservação Inicial

1. Sincronizar o relógio e registrar data e hora em Tempo Universal Coordenado UTC;
2. Criar diretórios 01_ORIGINAIS, 02_COPIAS_TRABALHO, 03_EXPORTACOES, 04_CAPTURAS, 05_LOGS e 06_RELATORIO;
3. Calcular SHA-256 com certutil -hashfile arquivo SHA256 ou ferramenta equivalente e conferir o hash após cada transferência;
4. Registrar nome, tamanho, tipo, origem, responsável, ferramenta, versão e observações em ficha própria.

7.2 Análise do e-mail

1. Examinar os campos From, Reply-To, Return-Path, Message-ID, Date, Received e Authentication-Results;
2. Verificar SPF, DKIM e DMARC, registrando que ausência ou falha não identifica isoladamente o remetente;
3. Extrair anexos e URLs sem abri-los; calcular hashes e neutralizar indicadores no formato hxxps e domínio[.]tld;
4. Comparar horário declarado, fusos, servidores intermediários e ordem dos cabeçalhos Received.

7.3 Infraestrutura e Conteúdo

1. Consultar RDAP, DNS, ASN e Certificate Transparency, preservando respostas brutas e capturas;
2. Consultar URLScan, VirusTotal e PhishTank somente com indicadores já públicos e não sensíveis;
3. Usar Wayback Machine e Archive.today para histórico, sem tratar ausência de snapshot como ausência pretérita;
4. Comparar textos, imagens e elementos de interface com o site legítimo; não inferir autoria a partir de semelhança visual.

8 Matriz de Ferramentas

Ferramenta	Entrada	Saída principal	Cautela
Thunderbird ou parser EML	Arquivo EML	Cabeçalhos, corpo, anexos e URLs	Desabilitar conteúdo remoto e scripts
ExifTool	EML, imagem ou anexo	Metadados técnicos	Ausência de metadados é inconclusiva
RDAP, Registro.br, DNSlytics	Domínio ou IP	Cadastro, DNS, ASN e histórico	Privacidade e nuvem limitam atribuição
crt.sh	Domínio	Certificados e nomes relacionados	Certificado não prova controle atual
URLScan	URL ou domínio público	Captura, requisições e infraestrutura	Evitar submissão pública de dado sensível
VirusTotal e PhishTank	Indicador público	Reputação e datas	Ausência de detecção não significa legitimidade

Ferramenta	Entrada	Saída principal	Cautela
Maltego CE e NetworkX	Entidades normalizadas	Grafo e relacionamentos	Relação gráfica não equivale a autoria
Python e Pandas	Resultados exportados	Normalização, métricas e logs	Preservar respostas brutas e versões

9 Registro e Cadeia de Custódia

Cada ação deverá produzir uma entrada de auditoria com identificador do caso, objeto, operador, ferramenta e versão, parâmetro, fonte, data e hora UTC, resultado, nome do arquivo, hash SHA-256 e observação. Originais não serão alterados. Conversões, recortes, OCR e demais derivados serão identificados como cópias de trabalho e relacionados ao objeto de origem.

10 Regras de Interpretação e Conclusão

Classe	Definição	Forma de Redação
Fato observado	Conteúdo diretamente verificado no objeto preservado	Foi observado no arquivo...
Dado externo	Informação fornecida por fonte identificada e datada	A fonte consultada informou...
Correlação	Relação sustentada por campos ou indicadores coincidentes	Os registros apresentam coincidência...
Inferência	Explicação compatível, dependente de premissas	Os achados são compatíveis com...
Hipótese	Possibilidade ainda carente de confirmação	Deve ser considerada a hipótese...

11 Produtos Técnicos e Operacionais Esperados

1. Guia Operacional para Investigação de Phishing e Personificação de Marca;
2. Procedimento Operacional Padrão para recepção, preservação e análise de e-mails suspeitos;
3. Procedimento Operacional Padrão para investigação passiva de URLs, domínios e infraestrutura de phishing;
4. Ficha de aquisição e preservação de evidência digital, com fonte, URL, data e hora UTC, ferramenta, versão, parâmetros, arquivo resultante e hash SHA-256;
5. Matriz de evidências e escala de confiança que distingam fato observado, informação externa, correlação, inferência e hipótese;

6. Grafo de relacionamentos, linha do tempo, corpus sanitizado, scripts auxiliares versionados e modelo de relatório técnico-pericial;
7. Artigo do Trabalho de Diplomação e material de treinamento destinado às Forças de Segurança e Lei.

12 Referências e Fontes Operacionais

ABNT. ABNT NBR ISO/IEC 27037: Diretrizes para identificação, coleta, aquisição e preservação de evidência digital. Rio de Janeiro: ABNT, 2013.

BRASIL. Decreto-Lei nº 3.689/1941. Código de Processo Penal, arts. 158-A a 158-F.

BRASIL. Lei nº 12.965/2014. Marco Civil da Internet.

BRASIL. Lei nº 13.709/2018. Lei Geral de Proteção de Dados Pessoais.

NIST. Guide to Integrating Forensic Techniques into Incident Response. SP 800-86, 2006.

NIST. Digital Evidence Preservation: Considerations for Evidence Handlers. IR 8387, 2022.

PHISHTANK. Developer Information. https://phishtank.org/developer_info.php.

URLSCAN.IO. Historical scan records. https://urlscan.io/.

CERTIFICATE TRANSPARENCY. Certificate Transparency Logs. https://certificate.transparency.dev/.

CW-L. Redacted real-world spam, scam and phishing email samples. https://github.com/cw-l/email-corpus.